

MODULE 1: INTRODUCTION TO COMPUTER SECURITY

Contents

Computer Security.....	1
Security Approaches	2
1. Prevention Approach:	2
2. Detection Approach	3
3. Response Approach	4
4. Recovery Approach	4
CIA Triad	5
1. Confidentiality	5
2. Integrity	6
3. Availability	7
Other Security Principles	7
1. Authentication	8
2. Authorization	8
3. Non-Repudiation.....	10
4. Accountability.....	10
5. Privacy	10
6. Principle of Least Privilege	11
7. Auditing	11

Computer Security

Computer Security refers to the protection of computer systems, networks, programs, and data from unauthorized access, attacks, damage, or theft. It ensures that information and resources remain safe from cyber threats. **Main Objectives of Security**

- | | |
|---------------------------------|---|
| 1. Protect data and information | 4. Maintain privacy and confidentiality |
| 2. Prevent unauthorized access | |
| 3. Ensure system reliability | 5. Prevent data loss and cyber attacks |

Need for Security

With the growth of the internet and digital communication, computer systems face many threats such as hacking, malware, phishing, and data theft. **Reasons Why Security is Needed**

1. **Protection of Data:** Sensitive information like passwords, bank details, and personal records must be protected.
2. **Privacy Protection:** Users expect their personal information to remain private.
3. **Prevent Financial Loss:** Cyber-attacks can cause huge financial damage to organizations.
4. **Prevent Unauthorized Access:** Only authorized users should access systems and resources.
5. **Business Continuity:** Security ensures systems continue functioning without interruption.

6. **National Security:** Government and defence systems require strong security mechanisms.

Security Approaches

Security approaches are the different methods and strategies used to protect computer systems, networks, and data from unauthorized access, attacks, and damage. No single security method is enough to provide complete protection. Therefore, organizations use multiple security approaches together to ensure better protection.

The major security approaches are:

- | | |
|---------------|-------------|
| 1. Prevention | 3. Response |
| 2. Detection | 4. Recovery |

1. Prevention Approach:

The prevention approach focuses on stopping attacks before they happen. It is the first line of defense in computer security. The main objective of prevention is to block unauthorized users and reduce vulnerabilities in the system. **Features:**

- | | |
|-------------------------------------|-------------------------------|
| • Stops attacks at an early stage | • Strengthens system security |
| • Protects confidential information | • Minimizes risk |
| • Reduces chances of data theft | |

Techniques Used in Prevention

A. Authentication: Authentication verifies the identity of a user before allowing access. Example: When users log into Gmail using a password and OTP, authentication is performed. Common methods include:

- | | |
|---------------------------|------------------------|
| • Username and password | • Fingerprint scanning |
| • OTP (One-Time Password) | • Face recognition |

B. Access Control: Access control limits who can access specific files or resources. Different users receive different permissions. Example:

- | | |
|-----------------------------|--|
| • Students can view marks | • Administrators can manage the whole system |
| • Teachers can modify marks | |

C. Encryption: Encryption converts readable information (plaintext) into unreadable form (ciphertext). Only authorized users with the decryption key can read the data. Example: Online banking transactions use encryption to secure financial information.

D. Firewall: A firewall acts as a barrier between a trusted network and an untrusted network. It monitors and filters incoming and outgoing traffic. Functions:

- | | |
|--------------------------------|------------------------------|
| • Blocks malicious traffic | • Protects internal networks |
| • Prevents unauthorized access | |

E. Antivirus Software: Antivirus software detects and removes malware such as viruses, worms, and trojans. Functions:

- | | |
|----------------------------|---------------------------------|
| • Scans files and programs | • Provides real-time protection |
| • Removes infected files | |

Examples:

- Windows Defender
- Quick Heal
- Norton Antivirus

Advantages of Prevention Approach

- Reduces chances of attacks
- Protects sensitive data
- Improves system reliability
- Prevents financial losses

Limitations

- Cannot stop all attacks
- Requires regular updates
- Advanced attackers may bypass protection

2. Detection Approach

The detection approach identifies attacks or suspicious activities occurring in a system or network. Even strong preventive measures may fail. Therefore, detection mechanisms are necessary to identify threats quickly. **Objectives**

- Identify attacks
- Monitor suspicious behavior
- Alert administrators
- Reduce damage

Techniques Used in Detection

A. Intrusion Detection System (IDS): IDS monitors network traffic and system activities for malicious behavior. Example: If a user attempts multiple failed logins, IDS may detect a brute-force attack. Types:

1. Network-based IDS (NIDS)
2. Host-based IDS (HIDS)

Functions:

- Detects unusual activities
- Generates alerts
- Logs suspicious events

B. Log Monitoring: Systems maintain logs of user activities and events. Administrators analyze logs to detect abnormal behavior. Examples of logged information:

- Login attempts
- System errors
- File access
- Network activities

C. Security Auditing: Security auditing involves reviewing system security policies and activities. Purpose:

- Identify vulnerabilities
- Improve security
- Ensure compliance

D. Malware Detection Tools: Security software scans systems to identify malicious programs.

Functions:

- Detect viruses and spyware
- Monitor file behavior
- Identify suspicious applications

Advantages of Detection Approach

- Quickly identifies attacks
- Helps prevent large-scale damage
- Improves monitoring capability

- Provides evidence for investigation

Limitations

- Cannot prevent attacks directly

- False alarms may occur
- Requires continuous monitoring

3. Response Approach

The response approach focuses on actions taken after detecting a security incident. The objective is to minimize damage and stop the attack from spreading. **Steps in Response Approach**

A. Identification: The organization identifies:

- Type of attack
- Affected systems
- Source of attack

B. Containment: Containment prevents the attack from spreading. Examples:

- Disconnect infected systems
- Block malicious IP addresses
- Disable compromised accounts

C. Elimination: The threat is removed from the system. Methods:

- Delete malware
- Patch vulnerabilities
- Remove unauthorized users

D. Investigation: Security experts analyze:

- How the attack occurred
- What damage was caused
- Which systems were affected

E. Notification: Organizations may inform:

- Users
- Customers
- Authorities
- Management

Especially in cases of data breaches.

Advantages of Response Approach

- Minimizes damage
- Controls attack spread
- Helps restore normal operations
- Improves future security planning

Limitations

- Attack may already have caused damage
- Requires skilled security teams
- Response delays may increase losses

4. Recovery Approach

Recovery is the process of restoring systems, networks, and data after an attack or failure. The main objective is to return the organization to normal working condition. **Recovery Techniques**

A. Backup Restoration: Data backups are used to restore lost or damaged information. Example: Recovering deleted company files from cloud backup. Types of backups:

- Full backup
- Incremental backup
- Differential backup

B. Disaster Recovery Plan (DRP): A disaster recovery plan is a structured plan to recover systems during emergencies. It includes:

- Recovery procedures
- Backup locations

- Emergency contacts
- System restoration steps

C. System Repair and Reinstallation:

Damaged operating systems or software may need repair or reinstallation.

D. Business Continuity Planning:

Ensures business operations continue even during attacks or failures. Example: Using backup servers when the main server fails.

Advantages of Recovery Approach

- Restores lost data
- Reduces downtime
- Ensures business continuity
- Helps organizations recover quickly

Limitations

- Recovery may take time
- Backup systems are costly
- Some data may still be lost

Relationship Between Security Approaches

All four approaches work together to provide complete security.

Approach	Main Goal
Prevention	Stop attacks before they occur
Detection	Identify attacks quickly
Response	Minimize damage during attacks
Recovery	Restore systems after attacks

CIA Triad

The CIA Triad is the fundamental model of Information Security. It consists of three major security principles:

1. Confidentiality
2. Integrity
3. Availability

The term “CIA” here does not refer to the intelligence agency. These three principles together help in designing secure computer systems, networks, and applications. The CIA Triad forms the foundation of Cryptography and Network Security.

1. Confidentiality

Confidentiality means protecting information from unauthorized access or disclosure. Only authorized users should be able to view sensitive data. It ensures privacy and secrecy of information.

Objectives of Confidentiality

- Prevent unauthorized access
- Protect private information
- Maintain secrecy of sensitive data
- Ensure data privacy
- Only account holders can access bank account details.
- Student marks should only be visible to authorized persons.
- Military secrets must remain confidential.

Examples

Methods Used to Achieve Confidentiality

1. **Encryption:** Encryption converts readable data (plaintext) into unreadable form (ciphertext). Only users with the correct decryption key can read the data. Example: HTTPS websites use encryption to secure communication.
2. **Authentication:** Authentication verifies the identity of users before access is granted. Examples: Passwords, OTP, Biometrics
3. **Access Control:** Access control restricts who can view or use information. Example: Employees may access only department-related files.
4. **Data Classification:** Data is categorized according to sensitivity.

Public	Information that can be freely shared without restrictions.
Private	Information intended for personal or limited use; not for general distribution.
Confidential	Sensitive information accessible only to authorized individuals; disclosure could cause harm.
Top Secret	Highly restricted information requiring maximum security clearance; disclosure could cause severe damage.

Advantages of Confidentiality

- Protects user privacy
- Prevents data theft
- sensitive information
- Maintains trust
- Secures

2. Integrity

Integrity means maintaining the accuracy, consistency, and correctness of data. Data should not be modified by unauthorized users. It ensures that information remains trustworthy. Objectives:

- | | |
|--|--|
| <ul style="list-style-type: none"> • Prevent unauthorized modification • Maintain data accuracy • Ensure reliability of information • Protect against accidental changes | Examples <ul style="list-style-type: none"> • Bank transaction amounts should not be altered illegally. • Examination marks should remain accurate. • Medical records should not be modified without authorization |
|--|--|

Methods Used to Achieve Integrity

1. **Hash Functions:** A hash function generates a fixed-size value called a hash or message digest. If data changes, the hash value also changes. Examples: SHA-256, MD5
2. **Digital Signatures:** verify: Data authenticity, Data integrity, Sender identity
3. **Checksums:** Checksums help detect errors during data transmission.
4. **Access Control:** Restricts unauthorized users from modifying files.

Advantages of Integrity

- Ensures accurate information
- Maintains trustworthiness
- Prevents data corruption
- Supports reliable decision-making

3. Availability

Availability ensures that systems, services, and data are accessible whenever needed by authorized users. Systems should remain operational and functional. **Objectives:**

- Ensure continuous service
- Minimize downtime
- Provide reliable access
- Support business continuity

Examples

- Online banking services should be available 24/7.
- Hospital databases must remain accessible during emergencies.
- E-commerce websites should remain active during high traffic.

Methods Used to Achieve Availability

1. **Data Backup:** Copies of important data are stored for recovery purposes.
2. **Redundancy:** multiple systems or servers are used so that backup systems can operate if one fails.
3. **Disaster Recovery Plan:** A structured recovery plan helps restore services after failures.
4. **UPS (Uninterruptible Power Supply):** Provides backup power during electricity failures.
5. **Load Balancing:** Traffic is distributed across multiple servers to prevent overload.

Advantages of Availability

- Ensures uninterrupted service
- Reduces downtime
- business operations
- Improves user satisfaction
- Supports

Relationship Between the Three Principles

The three principles work together to provide complete information security.

Principle	Main Focus
Confidentiality	Prevent unauthorized access
Integrity	Prevent unauthorized modification
Availability	Ensure continuous access

Importance of CIA Triad

- Forms the foundation of cybersecurity
- Helps design secure systems
- Protects sensitive information
- Maintains user trust
- Ensures reliable system operations

Other Security Principles

Apart from the CIA Triad, several additional principles are important for maintaining computer and network security. These principles ensure proper access control, accountability, trust, and secure communication. The important security principles are:

1. Authentication
2. Authorization
3. Non-Repudiation
4. Accountability
5. Privacy
6. Least Privilege
7. Auditing

1. Authentication

Authentication is the process of verifying the identity of a user, device, or system. It answers the question: “Who are you?” Only authenticated users are allowed to access the system.

Types of Authentication

1. **Knowledge-Based Authentication:** Based on something the user knows. Examples: Password, PIN, Security questions
2. **Possession-Based Authentication:** Based on something the user possesses. Examples: Smart card, ATM card, Mobile OTP
3. **Biometric Authentication:** Based on physical characteristics. Examples: Fingerprint, Retina scan, Face recognition
4. **Multi-Factor Authentication (MFA):** MFA combines multiple authentication methods for better security. Example: Password + OTP

Importance of Authentication

- Prevents unauthorized access
- Protects confidential data
- Ensures system security
- Verifies user identity

2. Authorization

Authorization determines what actions or resources an authenticated user can access. It answers the question: “What are you allowed to do?” **Example:** In a college management system:

- Students can view marks
- Teachers can update marks
- Admin can manage the database

Types of Authorization

A. Static & Structural Models

These models determine permissions based on identity, organizational structure, or explicit assignments.

1. **User-Based Authorization** Permissions are tied directly to an individual user account (e.g., "User *Alice* can read file X").
 - **How it works:** An Access Control List (ACL) explicitly maps individuals to resources.
 - **Pros/Cons:** Highly precise for a few users, but becomes a maintenance nightmare as an organization grows.
2. **Group-Based Authorization:** Users are pooled into collective "groups" (e.g., *Engineering*, *Marketing*), and permissions are granted to the group as a whole.
 - **How it works:** Instead of managing 50 individual engineers, you grant read/write access to the "Dev-Team" group.

- **Pros/Cons:** Simplifies management significantly compared to user-based control, but lacks granular context.
3. **Role-Based Authorization (RBAC):** Often confused with Group-Based control, RBAC abstracts access one step further by mapping permissions to a **job function or role** (e.g., *Admin, Editor, Billing Manager*), rather than just a department pool.
 - **How it works:** Roles are defined by business operations. Users inherit permissions by being assigned to a role.

B. Policy & Dynamic Models (What the context is)

These models move away from static roles and evaluate access requests in real-time based on variable characteristics and environmental factors.

1. **Attribute-Based Authorization (ABAC):** A highly flexible, next-generation model that evaluates policies using a combination of dynamic attributes.
 - **How it works:** It checks attributes across four categories:
 - **Subject:** (e.g., clearance level, job title).
 - **Resource:** (e.g., file type, department label, classification).
 - **Action:** (e.g., read, write, delete).
 - **Environment:** (e.g., current time, location).
 - **Example:** "Allow access if Subject.Title = 'Manager' and Resource.Type = 'Financial' and Environment.Time = 'Business Hours'."
2. **Context-Based Authorization:** This is a specific subset or implementation focus of ABAC. It ignores *who* you are for a moment and strictly evaluates the **transactional context** of the request.
 - **How it works:** It acts as a security guard analyzing external risks.
 - **Example:** Even if an Admin has the correct role, Context-Based systems will deny access if they log in from an unrecognized IP address, an unmanaged device, or a country where the company does not operate.

C. High-Security & Administrative Models (Who governs it)

These models define who has the authority to change security permissions in the first place.

1. **Discretionary Access Control (DAC):** In this model, the **creator or owner** of the resource has total discretion over who gets access.
 - **How it works:** The data owner can pass permissions to other users at will.
 - **Example:** The standard file system on your computer (NTFS/ext4) or a Google Doc where you choose to share a link with "Viewer" or "Editor" privileges.
 - **Risk:** High security risk, as a user could accidentally share sensitive data with the wrong person.

2. **Mandatory Access Control (MAC):** The most rigid and secure model, where access is centrally controlled by a system administrator or strict security policy. Individual users **cannot** change permissions, even on files they created.
- **How it works:** Resources and users are assigned security labels (e.g., *Unclassified*, *Secret*, *Top Secret*). Access is granted only if the user's clearance level matches or exceeds the resource's classification.
 - **Example:** Military computer networks or highly secure operating systems like SELinux.

Importance of Authorization

- Prevents misuse of resources
- Limits access rights
- Improves security management

3. Non-Repudiation

Non-repudiation ensures that a sender cannot deny sending a message and a receiver cannot deny receiving it. This principle provides proof of communication. **Example:** In online banking, digital signatures prove that a customer initiated a transaction. **Achieved Using**

- Digital signatures
- Encryption
- Time stamps

Importance:

- Prevents denial of actions
- Provides legal evidence
- Ensures trust in communication

4. Accountability

Accountability ensures that user activities can be tracked and monitored. Every action performed in the system should be traceable. **Example:** If a user deletes important files, administrators can identify who performed the action. **Achieved Using**

- Audit logs
- User activity records
- Monitoring systems

Importance

- Discourages malicious activities
- Helps investigations
- Improves transparency

5. Privacy

Privacy ensures personal and sensitive information is protected from unauthorized disclosure. Users should control how their information is collected and used. **Examples of Private Information:** Aadhaar number, Bank details, Medical records, Personal messages

Methods to Ensure Privacy

- Encryption
- Privacy policies
- Access restrictions

Importance

- Protects user rights

- Prevents identity theft
- Maintains trust

6. Principle of Least Privilege

This principle states that users should receive only the minimum permissions necessary to perform their tasks. **Example:** A normal employee should not have administrator privileges.

Advantages

- Reduces security risks
- Prevents accidental damage
- Limits attack impact

7. Auditing

Auditing is the process of reviewing and analysing system activities and security policies.

Objectives

- Detect vulnerabilities
- Monitor policy compliance
- Identify suspicious activities

Types of Auditing

A. Internal Audit: Conducted within the organization.

B. External Audit: Conducted by outside experts or organizations.

Importance of Auditing

- Improves security
- Detects weaknesses
- Ensures regulatory compliance